

Your supply chain has blind spots.

Three minutes from now, you'll know what they are.

Open Component Model — open source, NeoNephos Foundation.



THREE BLIND SPOTS

What today's delivery model can't see.

IDENTITY DRIFT

You signed the artifact at source.
Each transfer changes its reference.
Downstream verifies a reference you never signed.

NO RELEASE ENVELOPE

You sign artifacts. You don't sign the release.
Twelve pieces, twelve signatures — if you're lucky.

UNVERIFIED ARRIVAL

Sovereign zones forbid upstream traffic.
Verification ships with the release — or it doesn't happen.

WHY NOW

Sovereignty is no longer optional

SOVEREIGNTY PRESSURE

The law draws boundaries —
jurisdiction, sector, air-gap.

Software must be deliverable inside
each one.

REGULATION TIGHTENING

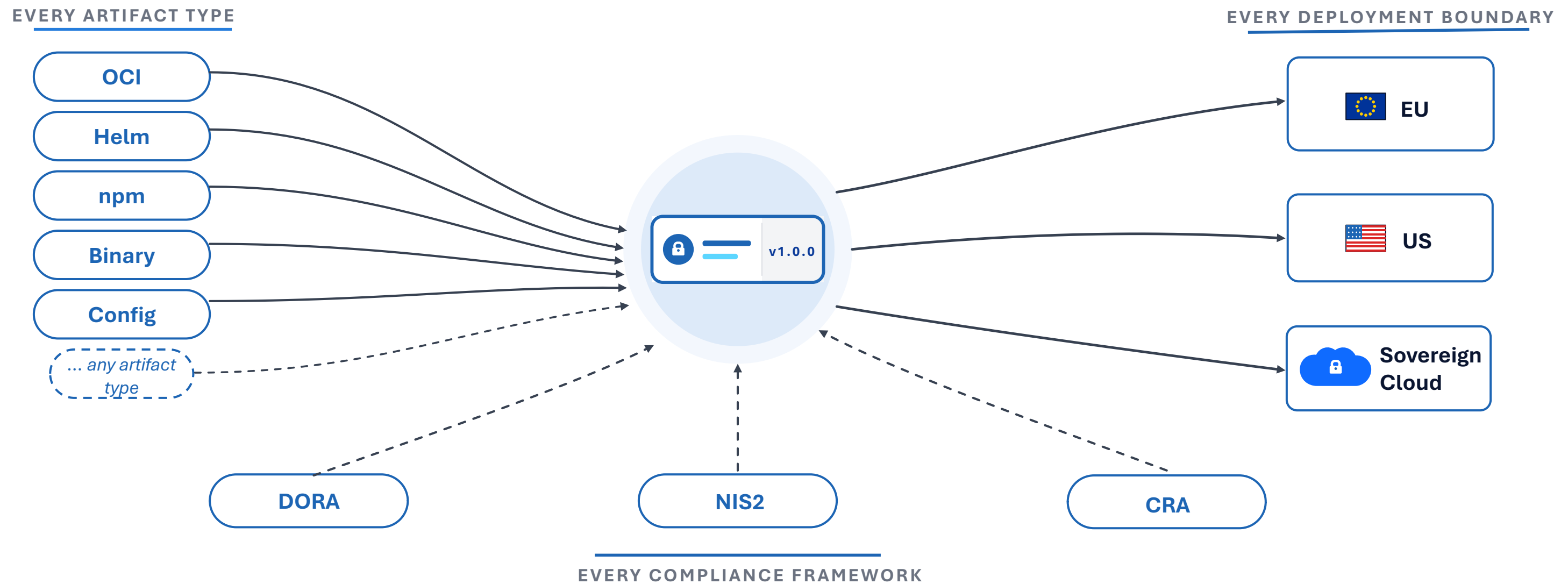
EU DORA · NIS2 · CRA. Provable
supply-chain control, not best
effort.

SUPPLY-CHAIN ATTACKS ARE REAL

SolarWinds. xz. log4shell.
Signatures must survive the journey,
or compliance is theatre.

THE ANSWER

Meet OCM. One identity, every boundary.



THE SHIFT

SBOM lists. SBOD delivers.

- SBOM - what's inside your software. Built for inventory.
- A Software Bill of Delivery (SBOD) - what you delivered, how to verify, transport, operate. Built for delivery.
- SBOD contains SBOM. OCM doesn't replace your SBOM tooling — OCM gives the SBOM an envelope.

THE SHIFT — SBOM INSIDE SBOD

What the envelope holds.

SOFTWARE BILL OF DELIVERY (SBOD)

`github.com/acme/app:v1.0.0`

Location-independent name. Same identity, every registry.



ARTIFACTS

What you delivered. How to verify it · how to operate it.



Docker Images



Helm Charts



Kubernetes Deployment Manifests



Configuration Files



SBOM



SIGNATURE

One digest covers all.

HOW OCM COMPOSES

Composes around your existing stack.

SIGNING

You sign artifacts.
OCM signs the release.

TRANSPORT

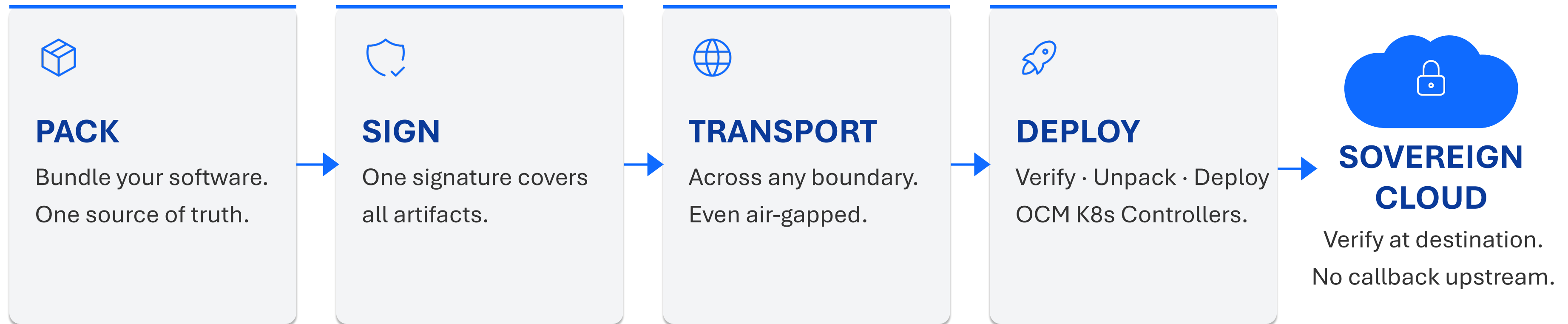
Your registries differ.
OCM moves the release across them.

COMPLIANCE

Your scanners see one artifact at a time.
OCM correlates findings to the release.

OCM IN ONE PICTURE

Pack · Sign · Transport · Deploy



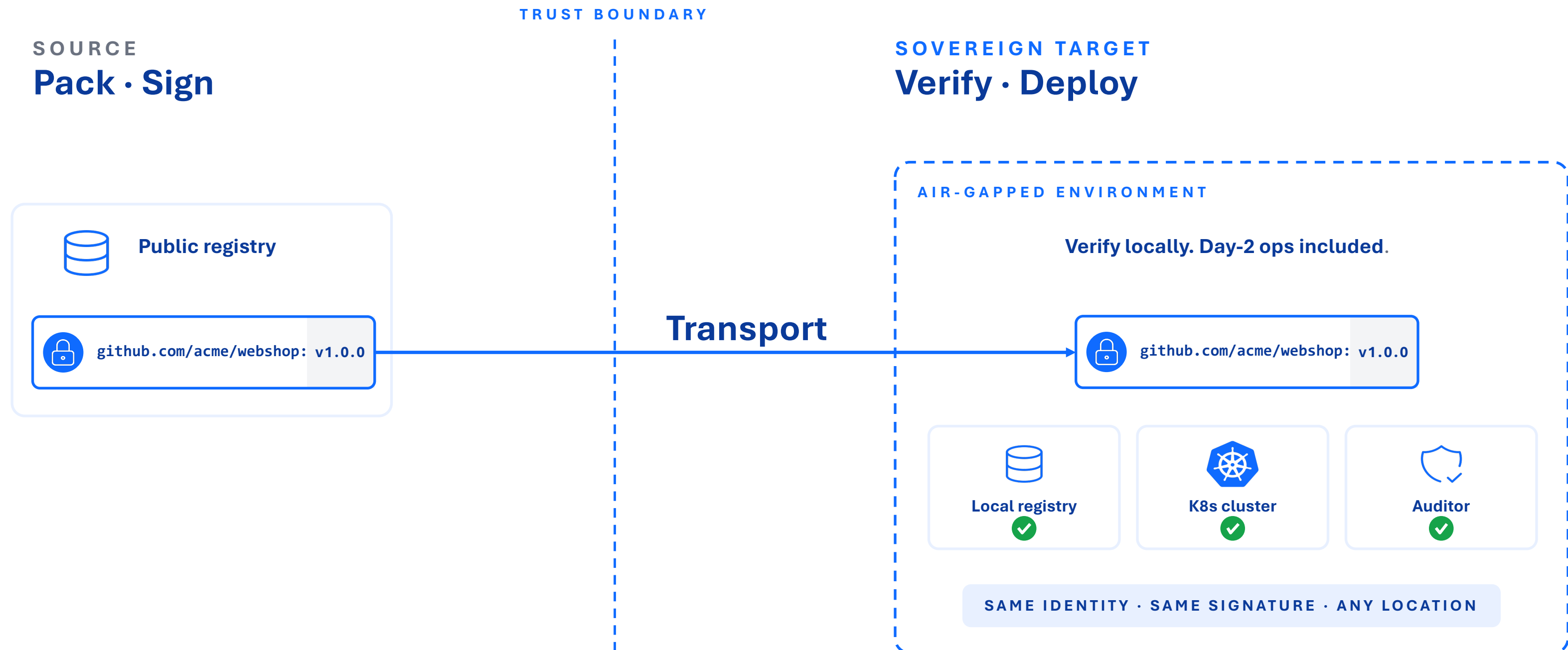
SOVEREIGN-READY

Trust, but verify.

- Identity — location-independent. The component carries its name regardless of registry.
- Signatures — location-independent. Sign once at source, verify anywhere downstream. No callback upstream.
- Transfer — self-contained. Every artifact travels with the component.
- Day-2 ops — happen inside the boundary. Subscribe, pull upgrades, scale across regions. Still no callback.

SOVEREIGN-READY — AIR-GAP

Trust travels with the component.



SCAN

Compliance as a system property — not a quarterly retrofit.

- The Compliance Dashboard — every component, every finding, one view.
- Continuous scans — asynchronous, even post-release.
- Contextual rescoring — patch what matters, not the noise.
- Identity-correlated evidence — auditors get answers, not spreadsheets.

WHAT OCM UNLOCKS

One model unlocks all of this.



Artifact signing across stacks

Sign once at source. Verify everywhere, with no per-stack tooling.



Air-gapped delivery

Walk a complete component across an air gap. Verify at destination.



Kubernetes-native deployment

OCM controllers deploy components directly into clusters.



Asynchronous security scans

Continuous scanning, even after release. Findings tied to component identity.



One source of truth

Rebuild any landscape from a single signed descriptor.



Automated compliance reporting

Reports composed from SBOD metadata — no spreadsheet drift.

TRUSTED IN PRODUCTION

**SAP stewards. NeoNephos governs.
Production-grade. Sovereign-ready.**



Start delivering with confidence.

Try it — ocm.software (QR code)

Build with us — github.com/open-component-model

Talk to us — community channels on the website



APPENDIX — ABBREVIATIONS

Quick reference for the acronyms used in this deck.

BSI C5 — Bundesamt für Sicherheit in der Informationstechnik — Cloud Computing Compliance Criteria Catalogue.

BTP — SAP Business Technology Platform.

CRA — Cyber Resilience Act — EU regulation on cybersecurity for products with digital elements.

DORA — Digital Operational Resilience Act — EU regulation on ICT risk management in financial services.

FedRAMP — Federal Risk and Authorization Management Program — US standardised cloud security assessment.

FISMA — Federal Information Security Modernization Act — US federal information security mandate.

Grype — Open-source vulnerability scanner for container images and filesystems (Anchore).

Helm — Package manager for Kubernetes; reference artifact type for OCM.

NeoNephos — European foundation for sovereign cloud open-source projects, hosted under the Linux Foundation.

NIS2 — Network and Information Security Directive 2 — EU baseline for cybersecurity of essential entities.

OCI — Open Container Initiative — open standards for container image format and distribution.

OCM — Open Component Model — vendor-neutral specification for signed, transportable software components.

ODG — Open Delivery Gear — OCM-native compliance automation engine and dashboard.

OSS — Open Source Software.

PKI — Public Key Infrastructure — framework for managing certificates and signing keys.

SBOD — Software Bill of Delivery — the OCM component descriptor, signed and traceable. Containing all artifacts and metadata for delivery and deployment.

SBOM — Software Bill of Materials — inventory of components and dependencies inside a software artifact.

SecNumCloud — French cloud security qualification scheme operated by ANSSI.

Sigstore — Open-source project for keyless software signing using OIDC identities.

SPDX — Software Package Data Exchange — ISO/IEC 5962 standard format for SBOM data.

SWID — Software Identification Tags — ISO/IEC 19770-2 standard for software inventory.

Trivy — Open-source security scanner for containers, IaC, and code (Aqua Security).